

DVWA WEB APPLICATION PENETRATION TEST REPORT

Capstone Project — Task 5

ApexPlanet Cybersecurity & Ethical Hacking Internship

Prepared by: Manivel R

Offer Letter ID: APSPL2640160

B.E. CSE (AI & ML), University College of Engineering, BIT Campus, Anna University

[Report Date]

Table of Contents

1. Executive Summary

Engagement Overview:

[2-3 sentences: what was tested, when, why]

Overall Risk Posture:

[One paragraph — e.g. 'DVWA at low security level exhibited critical vulnerabilities across all OWASP Top 10 categories tested. At high security level, most were effectively mitigated except X.']

Summary of Findings:

F-01	SQL Injection (Low security level)	Critical	Confirmed / Exploited
F-02	Reflected XSS	High	Confirmed / Exploited
F-03	Stored XSS	High	Confirmed / Exploited
F-04	CSRF - Password Change	Medium	Confirmed / Exploited
F-05	Local File Inclusion	Critical	Confirmed / Exploited
F-06	Remote File Inclusion	Critical	Confirmed / Exploited
F-07	No account lockout on failed login	Low	Confirmed

Key Recommendations:

- Use parameterized queries / prepared statements for all database interactions
- Implement Content Security Policy and output encoding for all user-controlled output
- Require anti-CSRF tokens on all state-changing requests
- Validate and whitelist file-inclusion parameters; disallow remote URLs
- Implement account lockout / rate limiting on authentication endpoints

2. Methodology

Scope:

[DVWA instance, all security levels (low/medium/high), IP addresses of attacker & target]

Approach:

This engagement followed a standard black-box to grey-box methodology:

- Reconnaissance — service/version identification (Nmap, Nikto)
- Vulnerability Analysis — manual review of each DVWA module at each security level
- Exploitation — manual and tool-assisted attacks against SQLi, XSS, CSRF, LFI/RFI
- Post-Exploitation — data extraction, session/cookie theft demonstration
- Incident Response Simulation — log analysis, detection, containment, eradication
- Reporting — this document

Tools Used:

Nmap, Nikto, Burp Suite (Proxy, Repeater, Intruder), sqlmap, Hydra, Wireshark, custom Python log-detection script.

Network Diagram:

[Insert network_diagram.svg (converted to PNG) here]

3. Detailed Findings

F-01. SQL Injection**Severity:**

[Critical / High / Medium / Low — justify with likelihood x impact]

Affected Component:

[DVWA module / URL / parameter]

Description:

[What the vulnerability is and why it exists at this security level]

Proof of Concept:

[Payload used, steps to reproduce, reference screenshot number in Appendix]

Evidence:

[Insert screenshot here — Figure X]

Impact:

[What an attacker could achieve (data exfiltration, session hijack, RCE, etc.)]

Mitigation:

[Specific fix — e.g. prepared statements, output encoding, CSRF tokens, input validation]

F-02. Reflected Cross-Site Scripting (XSS)**Severity:**

[Critical / High / Medium / Low — justify with likelihood x impact]

Affected Component:

[DVWA module / URL / parameter]

Description:

[What the vulnerability is and why it exists at this security level]

Proof of Concept:

[Payload used, steps to reproduce, reference screenshot number in Appendix]

Evidence:

[Insert screenshot here — Figure X]

Impact:

[What an attacker could achieve (data exfiltration, session hijack, RCE, etc.)]

Mitigation:

[Specific fix — e.g. prepared statements, output encoding, CSRF tokens, input validation]

F-03. Stored Cross-Site Scripting (XSS)**Severity:**

[Critical / High / Medium / Low — justify with likelihood x impact]

Affected Component:

[DVWA module / URL / parameter]

Description:

[What the vulnerability is and why it exists at this security level]

Proof of Concept:

[Payload used, steps to reproduce, reference screenshot number in Appendix]

Evidence:

[Insert screenshot here — Figure X]

Impact:

[What an attacker could achieve (data exfiltration, session hijack, RCE, etc.)]

Mitigation:

[Specific fix — e.g. prepared statements, output encoding, CSRF tokens, input validation]

F-04. Cross-Site Request Forgery (CSRF)**Severity:**

[Critical / High / Medium / Low — justify with likelihood x impact]

Affected Component:

[DVWA module / URL / parameter]

Description:

[What the vulnerability is and why it exists at this security level]

Proof of Concept:

[Payload used, steps to reproduce, reference screenshot number in Appendix]

Evidence:

[Insert screenshot here — Figure X]

Impact:

[What an attacker could achieve (data exfiltration, session hijack, RCE, etc.)]

Mitigation:

[Specific fix — e.g. prepared statements, output encoding, CSRF tokens, input validation]

F-05. Local File Inclusion (LFI)

Severity:

[Critical / High / Medium / Low — justify with likelihood x impact]

Affected Component:

[DVWA module / URL / parameter]

Description:

[What the vulnerability is and why it exists at this security level]

Proof of Concept:

[Payload used, steps to reproduce, reference screenshot number in Appendix]

Evidence:

[Insert screenshot here — Figure X]

Impact:

[What an attacker could achieve (data exfiltration, session hijack, RCE, etc.)]

Mitigation:

[Specific fix — e.g. prepared statements, output encoding, CSRF tokens, input validation]

F-06. Remote File Inclusion (RFI)

Severity:

[Critical / High / Medium / Low — justify with likelihood x impact]

Affected Component:

[DVWA module / URL / parameter]

Description:

[What the vulnerability is and why it exists at this security level]

Proof of Concept:

[Payload used, steps to reproduce, reference screenshot number in Appendix]

Evidence:

[Insert screenshot here — Figure X]

Impact:

[What an attacker could achieve (data exfiltration, session hijack, RCE, etc.)]

Mitigation:

[Specific fix — e.g. prepared statements, output encoding, CSRF tokens, input validation]

F-07. Insufficient Authentication Controls

Severity:

[Critical / High / Medium / Low — justify with likelihood x impact]

Affected Component:

[DVWA module / URL / parameter]

Description:

[What the vulnerability is and why it exists at this security level]

Proof of Concept:

[Payload used, steps to reproduce, reference screenshot number in Appendix]

Evidence:

[Insert screenshot here — Figure X]

Impact:

[What an attacker could achieve (data exfiltration, session hijack, RCE, etc.)]

Mitigation:

[Specific fix — e.g. prepared statements, output encoding, CSRF tokens, input validation]

4. Mitigation Summary

This section maps each finding to its concrete fix and, where applicable, shows the before/after behavior observed when DVWA's security level was raised.

[Table or paragraphs: Finding ID -> Root Cause -> Fix Applied -> Verification (re-tested at high security level, attack no longer succeeds)]

5. Incident Response Simulation

5.1 Detection

Logs were monitored during active exploitation using a custom detection script (log_detection.py) matching known attack signatures (SQLi, XSS, LFI patterns) against the Apache access log in real time.

[Insert log_detection.py output / findings.csv summary here]

5.2 Timeline

[Table: Timestamp | Event | Source IP | Action Taken]

5.3 Containment

The offending source IP was blocked at the host firewall:

```
sudo iptables -A INPUT -s <attacker_IP> -j DROP
```

5.4 Eradication

The underlying vulnerability was remediated by raising the DVWA security level (representing a code-level fix), and the attack was re-attempted to confirm it no longer succeeds.

5.5 Lessons Learned

[What detection gaps existed, what would improve response time, what monitoring should be permanent]

6. Appendix

A. Full Nmap output

[Paste or attach raw scan output]

B. Screenshots

[Figure 1, Figure 2, ... — reference these numbers in Section 3]

C. Raw tool output (sqlmap, Hydra, Burp)

[Attach or paste relevant excerpts]